Monthly Intelligence Dispatch

March 2022

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview by Group-IB, an international company that specializes in the prevention of cyberthreats and the development of information security products. The objective of the Dispatch is to inform readers about the current cyberthreats, attacks by criminal groups, data leaks, and new malware. This report includes news of arrests and legal actions against members of hacker groups, as well as short-term forecasts and warnings that will help you take timely measures to protect yourself against cyberthreats. Group-IB's MTID is prepared for in-house use only and is not intended for wide distribution.

Key findings

- **Yandex.Eda** reported a user data leak: threat actors used addresses, phone numbers, and order details to create a detailed interactive map of food delivery clients.
- Group-IB detected a mass mailout of spyware with **1371** addresses in total. During three weeks in March, the number of malicious mailouts in Russia increased twofold compared to the previous three weeks.
- Despite the detainment of seven members, the **Lapsus$** gang continued its attacks. Hackers claimed responsibility for breaking into systems of major tech companies, including **Nvidia**, **Samsung**, **Ubisoft, Microsoft**, and **Globant,** and threatening **Alphabet**, **Apple,** and **Meta**.
- The hacktivist group **Anonymous** claimed responsibility for DDoS attacks on Russian mass media, including TASS, Kommersant, RIA Novosti, and Forbes, hacking streaming services Wink and Ivi and online broadcasts of national TV channels.
- A banking Trojan Qakbot spreads by injecting itself in email communications.
- In 2021, the state lottery company Stoloto in cooperation with Group-IB blocked 23,685 fraudulent resources that mimicked popular state lotteries and illegally used the Stoloto brand.
- **Apple** and **Meta** transferred user data to hackers who masqueraded as police. The data included user IPs, phone numbers, and home addresses.
- The Moscow Region saw Pavel Vrublevsky, the founder and former CEO of ChronoPay, a payment service provider, detained by the police; two days later, he was arrested.

Main story: Yandex.Eda

Yandex.Eda	Yandex admitted that due to malpractice of one of their employees, phone numbers and order details of Yandex.Eda users were made public; the total volume of the leaked database amounted to 50 GB. The data leak did not impact payment data and user credentials. Later, the attackers used the leaked data to create an interactive client map containing real names, phone numbers, and addresses of thousands of clients. The website containing leaked data has been added to the register of violators of the rights of personal data subjects, and the access to it was limited. Yandex.Eda conducted an internal audit and implemented a stricter approach to storing confidential data to ensure that they are protected as vigorously as payment data. The company will no longer process this data manually and decrease threefold the number of employees who have access to it. The company filed a complaint addressed to Russian law enforcement about unauthorized access to clients' data; the perpetrator will be subject to the measures prescribed by law.

Key events: espionage, sabotage, data leaks

Lapsus$

A software developer **Globant** has confirmed it was breached by the hacker goup Lapsus$, adding to the cyber gang's growing list of victims. More than 70 GB of source code leaked in the Internet along with access data to DevOps platforms, including Confluence, Crucible, Jira, and GitHub. According to the hacker group, the access to the source code was obtained using a targeted attack on a third-party vendor that may have taken part in the development process. During the recent few weeks, the group claimed responsibility for hacking several major tech companies, including **Nvidia**, **Samsung**, **Ubisoft,** and **Microsoft**. Threat actors even announced the list of future victims that includes Alphabet, Apple, and Meta. At the end of March, BBC reported that the London police arrested seven individuals aged 16 to 21 who are allegedly members of the Lapsus$ group. There was no mention of whether the gang leader nicknamed White was among them.

Apple and Meta

Apple and **Meta** passed user data to hackers who masqueraded as police. The leaked data include IPs, phone numbers, and home addresses. Threat actors started with obtaining access to email accounts of the police department and then produced a fake request for urgent data provision, sending this form to victim companies. Hackers obtained access to official accounts of law enforcement authorities of various countries and starting from January 2021 have been sending fake requests to many companies. The attack is ascribed to the **Recursion Team** group, which is co-founded by the Lapsus$ leader White. The gang itself was dismissed, but some of its members joined **Lapsus$** under different monikers.

APT41

According to **Mandiant** experts, the group APT41 also known as **Double Dragon** hacked IT systems belonging to governments of six US states. To penetrate the systems, hackers used a zero-day vulnerability in a livestock monitoring app. After that, the group deployed in the network a custom-made malware known as **KEYPLUG**. It is a modular backdoor written in C++ that supports several network protocols for C&C traffic, including HTTP, TCP, and KCP over UDP and WSS. The malware was executed in Windows memory and periodically restarted as a scheduled task, which helped it uninterruptedly remain in the system. APT41 stole private data, but the specific goal of the campaign is not known.

Anonymous

The Anonymous hacktivist collective claimed responsibility for DDoS attacks on Russian mass media, including TASS, Kommersant, RIA Novosti, and Forbes, hacking streaming services Wink and Ivi and online broadcasts of national TV channels: Channel One Russia, Russia-24, and Moscow 24. During the night between March 11 and 12 they conducted an attack on a German subsidiary of Rosneft. According to hackers, they downloaded more than 20 TB of data as a result of this attack, but they do not intend to publish all of it, since their main targets are politicians and lobby groups.

Anonymous are not a traditional hacker group but rather a decentralized hacktivist movement. During international conflicts, they conduct DDoS attacks on mass media and governmental organizations hacking their websites to use them for publishing their own messages and radical texts. Inexperienced hackers, the so-called script kiddies, are also welcome to help as much as they can, e.g., monitor security perimeters of organizations in search for open ports, hosts with services running, or websites with easily detectable vulnerabilities. They also try their hand at backdooring external services using previously leaked databases, publish previously compromised data, and manage DDoS attacks to shut down key websites as part of information campaigns.

Spyware

Group-IB detected a mass mailout of spyware with 1371 addresses in total. During three weeks in March, the number of malicious mailouts in Russia increased twofold compared to the previous three weeks. Most of the time, they spread spyware (72% increase in the reporting period), backdoors (increased 131%), and loaders (increased 325%). Spywares help threat actors steal user credentials, bank card data, and other confidential information.

Google

Google's Threat Analysis Group reported two malicious campaigns conducted by North Korean hackers. Threat actors used the CVE-2022-0609 zero-day vulnerability in the Google Chrome browser. Attackers sent emails and under false pretenses persuaded users to visit fake or compromised legitimate websites that activated an exploit kit. The attacks were conducted by two hacker groups backed by the North Korean government. They were directed against mass media, IT companies, cryptocurrency and financial organizations impacting 335 users in total. The activities of the first gang were attributed to a North Korean cyber espionage campaign Operation Dream Job, while the second campaign is related to a group responsible for the operation AppleJeus. Google detected both campaigns on February 10 and four days later eliminated the vulnerability by releasing an emergency security update for Chrome.

Spring

Threat investigators found a vulnerability in the Spring framework, a tool to develop Java web apps, that puts many applications at risk of remote cyberattacks. The vulnerability was given two names: Spring4Shell and SpringShell. **Praetorian** and **Flashpoint** experts report that this new vulnerability can be exploited remotely if the Spring app is deployed on the Apache Tomcat server with a popular configuration. An attacker must identify the location and settings of the apps that use DeserializationUtils, since the vulnerability does not affect apps that work via Spring Boot and embedded Tomcat. To ensure secure settings, the framework will need a large-scale security update, which is currently being prepared.

Online fraud

Group-IB detected an outbreak of online fraud against the backdrop of the current geopolitical situation. Telephone fraudsters masquerade as bank employees informing customers that Russian banks have been removed from SWIFT and offering them to transfer their money to “safe” accounts. Another scheme involves fraudsters offering users to get credit cards from foreign banks and link them to an account in a Russian bank. After obtaining credit card data, fraudsters disappear. Sometimes criminals also offer services to prepare documents required to leave Russia or dodge conscription.

Social media saw numerous fake ads and mailouts that urge people to raise money for those affected by recent events in Ukrain, both on behalf of charity funds and public figures. Both sides of the conflict can be specified the beneficiaries of charity collections. For instance, fraudsters wrote a fake appeal from Sergei Shoigu, Russian minister of defense, asking for donations to help the Russian military.

On top of cases of Internet fraud, investigators detected some attempts to infect users' systems with malware, including fake mailouts on behalf of FSB offering to download an alleged security protocol against DDoS attacks. In another case, fraudsters offered to download a similar “information security” software from a fake website created on February 27 and decorated with the FSB logo. Instead, the website loaded the AveMaria RAT to a user’s computer to steal data, including user credentials.

Stoloto

In 2021, the state lottery company Stoloto in cooperation with Group-IB blocked 23,685 fraudulent resources that mimicked popular state lotteries and illegally used the Stoloto brand. Among them were 22,590 fraudulent websites, 1,021 fake accounts and social media groups, 74 mobile apps and 5 email addresses that were used to send phishing emails from.

Qakbot

The banking Trojan Qakbot spreads by embedding itself in emails. It automatically responds to incoming emails stored in the memory of an infected computer; this method is efficient in terms of social engineering because it makes emails sent by threat actors more trustworthy.

By the start of September, the number of compromised systems in the world reached 17,000, including 10,500 in Russia. The main goal of the virus is to steal account data to access financial services with cyber espionage and installing ransomware as additional functionalities. The virus has been known since 2007, and all this time it has been continuously evolving. It uses spam mailout as the main distribution channel, gaining access via stand-alone systems or corporate email servers, e.g., by using vulnerabilities ProxyLogon and ProxyShell. Using ProxyShell helps threat actors conduct mailouts from various email addresses simultaneously increasing the potential number of new infestations.

Russia	Group-IB reported that the number of ransomware attacks increased threefold starting from February 24. There was also a shift in the nature of attacks: before, ransomware operators were mostly financially motivated, whereas now there are more irreparable encryption cases when threat actors aim to disrupt the victim's business processes. In March, mass media reported incidents that affected the subsidiaries of the major Russian agribusiness holding Miratorg and one of Rosaviation's vendors leading to a potential leakage of 65 TB of data.
Pandora	The hacker group Pandora conducted an attack on a Japanese company Denso, a major vendor of Toyota. Attackers used ransomware threatening to reveal trade secret, including emails, invoices, and blueprints for components. The group claimed to gain access to more than 157,000 documents with a total size of 1,4 TB. According to the rating published by Automotive News, Denso is the second largest vendor of automotive components in the world, just behind Bosch. This February saw Kojima Press Industry, another vendor of Toyota, also falling victim to an attack, resulting in the company shutting down all its production facilities in Japan for a day.

Dark Crystal Rat

National Coordination Center for Computer Incidents warned about a malicious campaign that involves criminals embedding a malware called Dark Crystal Rat in information systems of Russian organizations. Hackers send phishing emails with malicious links on behalf of federal executive authorities. When a victim opens a link, their computer downloads malware modules that have protection against running in debuggers and virtual environments. Such modules collect cryptocurrency wallets, lists of running processes, network connection data, lists of connected USB devices, and operational system data. Phishing emails are sent from addresses that mimic mailboxes associated with law enforcement authorities.

Dell

Dell reported five new vulnerabilities with a high level of risk and recommended its clients to update BIOS on Alienware, Inspiron, Vostro, and Edge Gateway series 3000 as soon as possible. Vulnerabilities CVE-2022-24415, CVE-2022-24416, CVE-2022-24419, CVE-2022-24420 and CVE-2022-24421 are related to incorrect input verification that affects the System Management Mode (SMM) and help threat actors use System Management Interrupt (SMI) to execute an arbitrary code.

SMM is used in a special mode of the CPU in x86 micro controllers; their functionalities include power management, system equipment control, temperature monitoring, and other general system functions. Each time one of these operations is requested, a non-maskable interrupt (SMI) is called which executes the SMM code set in BIOS. This code is executed with maximum privileges and cannot be seen by a basic operating system, allowing the malicious code to run before the system boot.

Arrests and sentences

Pavel Vrublevsky

On March 10, The Moscow Region saw Pavel Vrublevsky, the founder and former CEO of ChronoPay, a payment service provider, detained by the police; two days later, he was arrested. Vrublevsky was charged with theft and fraud on a massive scale. The prosecutors' theory is that Vrublevsky and his colleagues have been deceiving people since 2019 by promising them money for participating in surveys, offering profits from stock exchange deals and support in various financial operations. Police believes that threat actors asked potential victims to pay a fee for registering on an Internet platform or receiving a cash transfer, and then stole the money via a social media or streaming service page under their control. Vrublevsky has a history of similar crimes: in 2013, he was sentenced to 2.5 years in prison for conducting DDoS attacks on the payment service **Assist**, a Chronopay's competitor.

Aleksei Burkov

Four members of the U.S. House Committees on the Judiciary, Homeland Security, Intelligence, and Foreign Affairs wrote Jake Sullivan, the national security advisor, to ask why a Russian hacker Aleksei Burkov aka K0pa was released from prison prematurely after spending there one year of his nine-year sentence. Burkov was running CardPlanet, a major carding forum that sold data of more than 150,000 bank cards. He also founded underground hacker forums DirectConnection and Mazafaka that attracted some of the most sought-after cybercriminals in the world. In 2015, Burkov was detained in Israel, and for four years Russian authorities strove to bring him back to Russia, proposing to swap him for an Israeli woman. But in 2019 Burkov was extradited to the US. Last year, however, he was released from prison and in August 2021 returned to Russia.

Forecasts and warnings

- Because of a spike in online fraud experts of **Group-IB Digital Risk Protection** recommend not to open links or download files received from unknown users by email, social media, or messengers, and do not talk to strangers on the phone if they offer any help with financial transactions or leaving the country. When transferring money to a charity organization, it is necessary to check the domain name of a website and a bank account number against official websites.
- Because of a threefold increase in ransomware attacks experts recommend Russian companies to take appropriate measures to prepare for this type of threat. The list of measures is published on the Group-IB website. It contains both basic rules that will help ramp up the security level of an organization and extreme measures to mitigate the risk of threat actors penetrating a company's infrastructure.
- One of the trends of 2021 in lottery-related fraud was using "hybrid" schemes along with traditional phishing and clone websites. Such schemes involve fake apps and conversations in messengers with government lottery representatives. You should not click on suspicious links, install remote access software upon request from alleged company employees, share codes from SMS or push notifications, bank card and personal data. When buying tickets online, always check transfer and payment details and use official lottery apps only.

Forecasts and warnings

- To protect your organization from a phishing campaign involving malicious mailouts from threat actors who masquerade as federal executive authorities, the National Coordination Center for Computer Incidents recommends to update antivirus databases regularly, download and open files only if they were received from trusted sources, check IT support systems and network traffic for indicators of malicious activity listed in the National Coordination Center's bulletin. When assessing the risk of compromise, it is necessary to analyze not only email attachments, but the links contained in incoming messages as well. The employees should be informed that following links and opening email attachments may be dangerous – even if they were sent from familiar addresses.
- To repel the targeted attacks conducted by Anonymous and other hacker groups Group-IB recommends to activate proactive security tools, e.g., Threat Hunting Framework, in advance, before the incident happens.

If you would like to receive more detailed information about a specific incident, threat, or criminal group, please contact us.

We conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com